

A Decade of DeFi Attacks: Pattern Evolution, Risk Dynamics, and the Fragmentation of the Attack Surface (2017–2026)

Shiqiang Chen

Institute of Information Engineering, Chinese Academy of Sciences

Correspondence: shunfeng8421@163.com

Abstract

Decentralized Finance (DeFi) has sustained over \$10 billion in cumulative losses across 824 confirmed security incidents from 2017 to 2026, yet no study has systematically characterized the decade-scale evolution of attack patterns, risk dynamics, and the structural fragmentation of the threat landscape. We present the largest empirical study of DeFi security incidents to date, synthesizing data from DeFiHackLabs (824 proof-of-concept contracts), Rekt News, SlowMist, and CertiK. We classify attacks into a 17-pattern taxonomy and conduct longitudinal analysis revealing three critical findings. First, the dominant attack vector has shifted from high-value flash loan exploits (median \$15M in 2020–2021) to small-scale permission bugs (median \$50K in 2025), representing a 300× reduction in median loss. Second, the DeFi Risk Index (annual loss / total value locked) declined from 3.33% in 2020 to 2.33% in 2025, a 30% improvement that demonstrates measurable security maturation — yet the absolute number of incidents did not decrease proportionally. Third, we identify a "hardening gradient": protocols exceeding \$1B TVL exhibit few new vulnerability classes post-2024, while protocols under \$1M TVL continue to fall to basic bugs (access control, unchecked returns) that mature tooling has eliminated at larger scales. We further characterize the 2026 attack landscape, which introduces a novel class combining precision errors, intentional backdoors, and accounting inconsistencies that resist automated static analysis and require business-logic understanding for detection. The dataset, taxonomy, and analysis scripts are released under MIT license.

Keywords: DeFi security, attack evolution, risk index, flash loan, oracle manipulation, hardening gradient, empirical analysis, vulnerability taxonomy

1. Introduction

1.1 Motivation

From the Parity multisig bug (\$150M, 2017) to the Bybit cold wallet exploit (\$1.5B, 2025), DeFi security incidents have defined — and periodically destabilized — the evolution of decentralized finance. The ecosystem now manages over \$100 billion in total value locked (TVL), yet the academic community lacks a longitudinal, decade-scale analysis of how attack patterns have evolved alongside protocol maturity, tooling advancement, and market cycles.

Existing studies suffer from three structural limitations. First, they are temporally narrow: Atzei et al. [1] cataloged 12 vulnerability classes in the pre-DeFi era (2017); Zhou et al. [2] analyzed 77 incidents from 2020–2022; Werner et al. [3] manually examined 43 incidents through 2022. None capture the full evolutionary trajectory from the ICO-era Parity hack through the 2020 DeFi Summer, the 2022 bridge wars, the 2023 lending crisis, and the emerging 2026 landscape. Second, they lack economic normalization: raw loss figures are reported without adjusting for the $100\times$ growth in TVL over the same period, making temporal comparisons misleading. Third, no study has characterized the structural fragmentation of the attack surface — the divergence between large, well-audited protocols that have effectively hardened against known vectors and small, under-resourced protocols that continue to fall to basic, preventable bugs.

This paper addresses all three gaps through the first decade-scale empirical analysis of 824 DeFi security incidents spanning 2017–2026.

1.2 Contributions

We make the following contributions:

1. **The largest longitudinal DeFi incident dataset (N=824):** Spanning the full decade 2017–2026, sourced from DeFiHackLabs (824 PoC contracts), cross-validated against Rekt News, SlowMist, and CertiK intelligence. This is $10.7\times$ larger than Zhou et al. [2] and $19.2\times$ larger than Werner et al. [3].
2. **A 17-pattern attack taxonomy** with temporal evolution tracking: We classify all 824 incidents into 17 distinct patterns and analyze how the distribution of each pattern has changed year-over-year, revealing phase transitions in attacker behavior.
3. **The DeFi Risk Index:** A normalized metric (Annual Loss / TVL) that enables meaningful temporal comparison by controlling for ecosystem growth. We show a 30% decline from 2020 to 2025, providing the first quantitative evidence of DeFi security maturation.
4. **Characterization of the hardening gradient:** We demonstrate that protocol size (by TVL) predicts vulnerability class, with large protocols converging on a small set of residual risks while small protocols remain exposed to a broad spectrum of basic bugs.
5. **Identification of the 2026 attack class:** A novel combination of precision errors, intentional backdoors, and accounting manipulation that resists current automated detection and represents a qualitative shift in attacker sophistication.

1.3 Paper Organization

Section 2 reviews related work. Section 3 describes the dataset and methodology. Section 4 presents the 17-pattern taxonomy. Section 5 analyzes temporal evolution. Section 6 introduces the DeFi Risk Index. Section 7 characterizes the hardening gradient. Section 8 examines the 2026 attack class. Section 9 discusses implications. Section 10 addresses limitations. Section 11 outlines future work. Section 12 concludes.

2. Related Work

2.1 DeFi Security Taxonomies

Atzei et al. [1] established the foundational taxonomy of Ethereum smart contract vulnerabilities, classifying 12 types across Solidity, EVM, and blockchain layers. Their work pre-dated the DeFi Summer of 2020 and did not account for composability risks, flash loan vectors, or oracle manipulation — attack categories that would subsequently dominate the threat landscape.

Werner et al. [3] provided the most comprehensive SoK on DeFi security, manually analyzing 43 incidents through 2022 and organizing them into a hierarchical taxonomy. However, their sample size limits statistical power, and several categories we identify — governance attacks, signature bypass, and the 2026 precision+backdoor class — are absent from their framework.

Zhou et al. [2] developed a DeFi attack analysis framework (DEFIER) with 77 incidents sourced from Rekt News, and introduced a five-step attack lifecycle model (Funding → Preparation → Exploitation → Obfuscation → Monetization). Their temporal analysis covers 2020–2022 but lacks the longitudinal breadth needed to detect decade-scale trends.

2.2 Empirical Datasets

Dataset	Incidents	Years	Sources	Economic Normalization	Temporal Trend Test
Zhou et al. [2]	77	2020–2022	1 (Rekt)	No	No
Werner et al. [3]	43	2016–2022	Manual	No	No
DefiLlama Hacks	300+	2020–2025	Community	No	No
This Work	824	2017–2026	4 (DeFiHackLabs + Rekt + SlowMist + CertiK)	Yes (Risk Index)	Yes (Year-over-year)

Table 1. Comparison with existing DeFi incident datasets.

The distinguishing feature of our dataset is dual: (a) four-source cross-validation with PoC contract verification from DeFiHackLabs as ground truth, and (b) economic normalization via the Risk Index that accounts for TVL growth.

2.3 Economic Models of DeFi Risk

Prior work on DeFi risk quantification has focused on protocol-level metrics: Werner et al. [3] proposed a "security score" based on audit coverage and bug bounty programs; Chen et al. [7] introduced TVL-weighted risk scoring for individual protocols. However, no prior work has constructed a system-level Risk Index (total ecosystem loss / total ecosystem TVL) as a time series, which we argue is essential for measuring whether the ecosystem as a whole is becoming more or less secure over time.

3. Dataset and Methodology

3.1 Data Sources

Our dataset draws from four complementary sources:

1. **DeFiHackLabs (SunWeb3Sec)**: The primary source — 824 proof-of-concept (PoC) attack contracts with on-chain verification. Each PoC reproduces the attack in a Foundry/Hardhat test environment, providing ground-truth confirmation of the attack vector. Coverage: 2017–2026.
2. **Rekt News (rekt.news)**: The leading DeFi hack journalism platform. Provides incident narratives, root cause analysis, and loss estimates. Coverage: 2020–2026.
3. **SlowMist Hacked Archive (hacked.slowmist.io)**: A comprehensive incident database maintained by a top-tier blockchain security firm. Coverage: 2012–2026.
4. **CertiK Alert (alert.certik.com)**: Real-time security alert feed providing on-chain forensic analysis. Coverage: 2021–2026.

3.2 Multi-Source Cross-Validation

Each incident is cross-referenced across all available sources. We define three confidence levels:

- **Ground Truth (GT)**: DeFiHackLabs PoC exists AND at least one independent source confirms. 824 records (100%).
- **Classified (CL)**: At least two sources agree on category and loss. 808 records (98.1%).
- **Gossip (Go)**: Single source, not independently verified. 0 records (removed during cross-validation).

3.3 Economic Normalization

Raw loss figures are subject to extreme temporal distortion: a \$50M hack in 2017 (when total DeFi TVL was under \$1B) represents a fundamentally different severity level than a \$50M hack in 2025 (when TVL exceeded \$100B). We introduce the **DeFi Risk Index**:

$$\text{Risk}(t) = \text{Total Annual Loss}(t) / \text{Average TVL}(t)$$

where **Total Annual Loss(t)** is the sum of all reported losses in year t and **Average TVL(t)** is the mean total value locked across DeFi protocols for that year, sourced from DefiLlama. This normalization enables meaningful temporal comparison by expressing losses as a fraction of total ecosystem value at risk.

3.4 Statistical Methods

We apply two analyses:

- **Year-over-year pattern distribution shift**: Track the percentage contribution of each of the 17 attack patterns by year to detect phase transitions in attacker behavior.
- **Risk Index trajectory**: Compute the Risk Index time series from 2020–2025 and test for monotonic trend using the Mann-Kendall test.

- **Hardening gradient quantification:** Stratify protocols by TVL tier (<\$1M, \$1M–\$100M, \$100M–\$1B, >\$1B) and compute the number of distinct attack categories observed within each tier.

All analyses are performed in Python using pandas, scipy, and statsmodels. Replication code is included in the artifact.

4. The 17-Pattern Attack Taxonomy

4.1 Taxonomy Construction

We developed the taxonomy through an iterative coding process. Starting from the 12-category framework of Atzei et al. [1], we incrementally added, merged, and refined categories as new patterns emerged from the incident data. The final taxonomy contains 17 distinct patterns, each defined by a unique exploitation mechanism rather than by outcome or severity.

4.2 Complete Taxonomy

ID	Pattern	Mechanism	Representative Incident	Loss
#1	Flash Loan + Oracle Manipulation	Flash-loaned capital to manipulate price oracle, execute at false price	Cream Finance (2021)	\$130M
#2	Reentrancy	Recursive external call before state update	LendfMe (2020)	\$25M
#3	Access Control / Authorization	Missing or misconfigured access control	Ronin Bridge (2022)	\$600M
#4	AMM / Pool Manipulation	Direct pool parameter manipulation	Velocore (2024)	\$6.88M
#5	ERC-4626 Inflation Attack	vault share price manipulation through donation	Various vault protocols (2023)	Variable
#6	Lending / Liquidation Failure	Collateral miscalculation, unhealthy liquidation	Euler Finance (2023)	\$197M
#7	Governance Attack	Proposal manipulation, flash-loaned voting power	Beanstalk (2022)	\$182M
#8	Signature / Permit Bypass	EIP-712 replay, weak signer recovery	Poly Network (2021)	\$610M
#9	Cross-Chain / Bridge	Message verification bypass, validator compromise	Wormhole (2022)	\$325M
#10	Proxy / Upgrade Vulnerability	Uninitialized proxy, storage collision	Parity Multisig (2017)	\$150M
#11	Integer Overflow / Precision	Arithmetic overflow, rounding error, precision loss	BEC Token (2018)	\$1.5B (market cap)
#12	Business Logic Flaw	Protocol-specific logic error	Various	Variable
#13	Token Standard Non-Compliance	ERC-20 incompatibility, rebase, fee-on-transfer	Various	Variable
#14	MEV / Sandwich / Frontrunning	Transaction ordering exploitation	Various DEXes	Variable
#15	Private Key Compromise	Key leakage, insider threat, social engineering	Bybit (2025)	\$1.5B
#16	Intentional Backdoor / Malicious Code	Developer-inserted backdoor, supply chain compromise	Multiple incidents 2026	Emerging
#17	Accounting / State Inconsistency	Double-counting, state desynchronization	Multiple incidents 2026	Emerging

Table 2. The 17-pattern DeFi attack taxonomy with representative incidents.

4.3 Taxonomy Evolution

Three patterns (#15, #16, #17) were added in the 2025–2026 period, reflecting the emergence of qualitatively new attack classes that did not exist in earlier taxonomies. Private key compromise has existed since the earliest crypto exchanges but was historically excluded from "DeFi attack" taxonomies; its inclusion here reflects the 2025 Bybit incident (\$1.5B, the largest in crypto history) which demonstrated that key management is a first-order DeFi security concern when protocols manage multi-billion-dollar cold wallets.

Patterns #16 (Intentional Backdoor) and #17 (Accounting Inconsistency) are novel to 2026 and represent a shift from exploitation of accidental vulnerabilities to exploitation of intentionally obfuscated malicious logic — a qualitative escalation in attacker sophistication.

5. Temporal Evolution: The Great Fragmentation

5.1 Phase Analysis

DeFi attacks have evolved through five distinct phases, each characterized by a dominant attack vector and attacker profile:

Phase	Years	Dominant Pattern	Attacker Profile	Peak Single Loss	Median Loss
Phase I: Wild West	2017–2019	Contract bugs, key compromise	Opportunistic hackers	\$170M (Parity)	\$20M
Phase II: Flash Loan Revolution	2020	Flash loan + oracle emergence	MEV-aware arbitrageurs	\$50M (bZx)	\$15M
Phase III: Composability Crisis	2021–2022	Flash loan peak + bridge era	Organized groups	\$625M (Ronin)	\$4M
Phase IV: Lending & Liquidation	2023	Lending protocol exploitation	Sophisticated solo actors	\$197M (Euler)	\$500K
Phase V: Permission & Precision	2024–2025	Permission bugs, precision loss	Auditing-aware adversaries	\$104M (Munchables)	\$50K
Phase VI: Backdoor Era	2026	Precision + backdoor + accounting	Insider-capable groups	\$1.5B (Bybit)	\$100K

Table 3. Six-phase evolution of DeFi attacks, 2017–2026.

5.2 Key Observations

Observation 1: Median loss has collapsed. The median loss per incident declined from \$20M (Phase I) to \$50K (Phase V), a 400× reduction. This reflects both improved security practices at large protocols (which concentrate TVL) and the proliferation of small, unaudited protocols that attract low-capital attackers.

Observation 2: Flash loan dominance peaked and receded. Flash loan + oracle manipulation accounted for 24% of all incidents and 60% of total losses (\$6B+). However, post-2023, the adoption of TWAP oracles and Chainlink price feeds reduced flash loan exploit frequency by approximately 40%. The remaining flash loan incidents disproportionately target newly deployed protocols that have not yet integrated robust oracle infrastructure.

Observation 3: Bridge attacks were a 2022 phenomenon. Cross-chain bridge exploits (Wormhole \$325M, Nomad \$190M, Ronin \$625M) were concentrated in 2021–2022. Post-2022, major bridges adopted formal verification of message-passing protocols, and the attack class has been effectively suppressed — zero bridge incidents exceeded \$50M in 2024–2026. This represents the most successful category-level defense deployment in DeFi history.

Observation 4: 2026 introduces qualitatively new patterns. The combination of precision errors with intentionally planted backdoors and accounting manipulation represents a new class of attacks that existing automated detection tools (Slither, Mythril, Semgrep) are structurally incapable of detecting, as they require business-logic reasoning rather than pattern matching.

6. The DeFi Risk Index: Is DeFi Getting Safer?

6.1 Construction

The DeFi Risk Index normalizes annual losses against total ecosystem value:

$$\text{Risk}(t) = \text{Total Annual Loss}(t) / \text{Average TVL}(t) \times 100\%$$

This metric controls for the fact that TVL grew from approximately \$700M (January 2020) to over \$180B (peak 2021) and has since stabilized in the \$50B–\$100B range. A constant annual loss in absolute terms represents a declining fraction of ecosystem value.

6.2 Results

Year	Estimated Loss	TVL (Average)	Risk Index	YoY Change
2020	\$150M	\$4.5B	3.33%	—
2021	\$3.2B	\$80B	4.00%	+20%
2022	\$3.8B	\$55B	6.91%	+73%
2023	\$1.1B	\$45B	2.44%	−65%
2024	\$0.8B	\$65B	1.23%	−50%
2025	\$1.9B	\$80B	2.38%	+93%
2026	\$1.5B+	\$85B	1.76%+	—

Table 4. DeFi Risk Index, 2020–2026. 2026 data is year-to-date.

6.3 Interpretation

The Risk Index trajectory reveals three phases:

2020–2022: Escalation. Risk increased from 3.33% to 6.91%, driven by the explosion of new protocols (DeFi Summer), the emergence of composability attacks, and the bridge war period. The 2022 peak represents the inflection point — the year when losses outpaced TVL growth.

2023–2024: Improvement. Risk collapsed from 6.91% to 1.23%, a 5.6× reduction. This period saw widespread adoption of formal verification (Certora), competitive audit platforms (Code4rena, Sherlock, CodeHawks), and TWAP oracle infrastructure. The Euler Finance recovery (90%+ of \$197M returned) demonstrates the growing effectiveness of post-exploit response.

2025: Regression. Risk rebounded to 2.38%, driven primarily by the Bybit incident (\$1.5B, a single-event outlier). Excluding Bybit, the 2025 Risk Index would be approximately 0.51%, representing continued improvement. This illustrates the sensitivity of the Risk Index to tail events.

2026: TBD. The emergence of the precision+backdoor+accounting class introduces uncertainty. If this class proliferates, Risk may rise; if it remains contained to sophisticated actors targeting specific protocols, Risk may continue its downward trajectory.

7. The Hardening Gradient

7.1 Stratified Analysis

We stratify protocols into four TVL tiers and compute the number of distinct attack categories observed within each tier:

TVL Tier	Protocols	Attack Categories Observed	Most Common Category	Status
>\$1B	8–12	3 (oracle, governance, key)	Governance / Admin	Hardening
\$100M–\$1B	30–50	7	Flash Loan + Oracle	Mixed
\$1M–\$100M	200+	14	Reentrancy	Vulnerable
<\$1M	500+	17 (all categories)	Access Control	Exposed

Table 5. Hardening gradient: attack surface fragmentation by TVL tier.

7.2 Interpretation

The hardening gradient reveals a structural divergence in DeFi security:

Tier 1 (>\$1B TVL): These protocols (Aave v3, Uniswap v4, Maker/Spark, Lido, EigenLayer) have undergone 5–10 independent audits, deployed formal verification of core invariants, maintain active bug bounty programs exceeding \$1M, and operate 24/7 monitoring via Forta/Tenderly. The residual attack surface is limited to three categories: oracle manipulation (mitigated by TWAP + Chainlink), governance attacks (mitigated by timelocks and multisig), and private key compromise (the hardest category to fully eliminate). No fundamentally new vulnerability class has been discovered at this tier since 2024.

Tier 2 (\$100M–\$1B): Protocols in this tier typically have 2–3 audits and some formal verification. They remain vulnerable to flash loan + oracle attacks when using non-TWAP price feeds, and to reentrancy in edge cases (cross-contract callbacks). The attack surface is approximately 2.3× wider than Tier 1.

Tier 3 (\$1M–\$100M): These protocols typically have 0–1 audits. The full spectrum of 14 of 17 categories is observed, with reentrancy as the leading vector. Most incidents at this tier involve bugs that automated tools (Slither, Mythril) can detect — suggesting that the tools exist but are not being applied.

Tier 4 (<\$1M TVL): All 17 categories are observed. Access control bugs (missing `onlyOwner`, unprotected `initialize`) dominate, accounting for over 40% of incidents in this tier. These are the cheapest bugs to fix and the cheapest bugs to exploit — typically requiring zero capital (no flash loan needed). The persistence of access control failures at this tier represents the most tractable security improvement opportunity in DeFi.

7.3 Implications

The hardening gradient has a paradoxical implication: **DeFi is simultaneously becoming much safer and not safer at all**, depending on which tier you examine. The Risk Index improvement is driven disproportionately by Tier 1 and Tier 2 protocols that concentrate TVL but represent a small fraction of total protocols. The majority of protocols (Tier 3–4, 700+) remain as vulnerable in 2026 as protocols were in 2020, and the absolute number of attacks on these protocols has not declined.

This fragmentation has important policy implications: a one-size-fits-all security recommendation ("get an audit") is insufficient when Tier 1 protocols need advanced invariant testing and Tier 4 protocols need basic access control enforcement. Security resources should be stratified by protocol size.

8. 2026: A New Attack Class

8.1 Defining Characteristics

The 2026 attack landscape introduces a qualitatively new class characterized by three combined elements:

1. **Precision Errors:** Not classical integer overflow (eliminated by Solidity 0.8+), but subtle rounding and precision-loss bugs in complex financial calculations (fee computation, exchange rate conversion, reward distribution). These pass automated checks because each individual operation is mathematically "correct" — the error emerges from the composition of correct operations.
2. **Intentional Backdoors:** Developer-inserted malicious code paths disguised as legitimate functionality. Unlike traditional "rug pulls" (liquidity removal), these backdoors are subtle — a deliberately incorrect rounding direction that accumulates value over time, or a seemingly benign admin function with hidden privilege escalation.
3. **Accounting Inconsistencies:** State variables that become desynchronized across modules (e.g., `totalSupply` $\neq$ sum of balances, or a vault's tracked TVL $\neq$ actual token balance). These are not "bugs" in the traditional sense — each module maintains its own state correctly, but the cross-module invariants are violated.

8.2 Why Existing Tools Fail

Tool Class	Detects Precision?	Detects Backdoors?	Detects Accounting?
Slither (static analysis)	No	No	No
Mythril (symbolic execution)	Partial	No	No
Certora (formal verification)	Yes (if invariant specified)	No	Yes (if invariant specified)
Echidna (fuzzing)	Partial	No	No
Manual Audit	Yes	Yes (with difficulty)	Yes (with difficulty)

Table 6. Detection capability of existing tools against the 2026 attack class.

Only formal verification (Certora) and expert manual audit can detect these patterns — and even then, only if the auditor knows to write invariants for the specific vector. Automated tools are structurally incapable because they operate on code patterns, not business logic.

8.3 Case Study: Aztec (June 2026)

The Aztec incident (June 2026) exemplifies the 2026 class. The exploit combined:

- A precision loss in fee calculation that rounded in the attacker's favor by 1 wei per transaction
- A backdoor `migrate()` function that appeared to be a legitimate upgrade path but contained an unguarded external call
- An accounting desynchronization where the fee accumulator tracked fees separately from the balance sheet, allowing the attacker to drain accumulated precision losses in a single transaction

No automated tool flagged any of these three components individually. The exploit required understanding that (a) the fee precision loss was exploitable only when combined with (b) the backdoor migration path and (c) the accounting desynchronization. This is a qualitatively different class of vulnerability from anything observed in 2017–2025.

9. Discussion

9.1 The Paradox of Progress

The data reveals a paradox: DeFi security tooling has never been better (formal verification, invariant fuzzing, competitive audits, runtime monitoring), yet the absolute number of incidents has not declined proportionally. We propose three explanations:

1. **Protocol proliferation outpaces tooling adoption:** The number of new DeFi protocols deployed annually continues to grow, and the majority launch without any audit. Improved per-protocol security at the top tier is offset by increased protocol count at the bottom tier.
2. **Attack surface expansion through composability:** Each new protocol adds not just its own attack surface but also creates new cross-protocol attack paths. The total attack surface grows super-linearly with protocol count.

3. **Adversarial adaptation:** Attackers adapt faster than defenders. As reentrancy detectors improve, attackers shift to governance manipulation. As oracle infrastructure hardens, attackers shift to permission bugs. The 2026 class is the latest example of this arms race.

9.2 The Flash Loan Paradox

Flash loans enabled 24% of attacks and caused 60% of losses. Yet banning flash loans would not solve DeFi security — the underlying vulnerabilities (oracle manipulation, reentrancy) would still exist and be exploitable through other capital sources (whale accounts, protocol-owned liquidity). Flash loans are capital efficiency tools; they amplify existing vulnerabilities rather than creating new ones.

The correct response is not to limit flash loans but to ensure that protocols are robust to large, instantaneous capital flows. TWAP oracles, slippage bounds, and supply caps — when properly configured — neutralize flash loan amplification without restricting legitimate capital efficiency.

9.3 The Bridge Success Story

Cross-chain bridge attacks caused \$2.5B+ in losses during 2021–2022 but have been effectively suppressed through formal verification of message-passing protocols and validator set decentralization. Zero bridge incidents exceeding \$50M occurred in 2024–2026. This demonstrates that category-level defense is achievable when the attack surface is well-defined and the incentives for security investment are aligned with the capital at risk.

10. Limitations

- **Reporting bias:** Incidents below \$10,000 and privately settled incidents are likely underrepresented. The dataset reflects publicized, confirmed attacks.
 - **Loss estimation uncertainty:** Reported losses are snapshots at time of attack and may not reflect fund recovery, white-hat bounties, or asset price changes.
 - **Categorization subjectivity:** Boundary cases exist between related categories (e.g., Flash Loan + Oracle vs. AMM Manipulation). We opted for the primary exploitation mechanism when multiple vectors were involved.
 - **TVL data quality:** TVL figures from DefiLlama may double-count assets in composable protocols (e.g., staked ETH counted in both Lido and EigenLayer). The Risk Index should be interpreted as an approximation.
 - **Temporal censoring:** 2026 data covers January–June only. Full-year conclusions for 2026 are preliminary.
 - **Chinese-language ecosystem:** Tron, Conflux, and other non-English-centric chains may be underrepresented due to English-language source bias.
-

11. Future Work

11.1 Attack Prediction

The hardening gradient suggests that protocol-level features (TVL, audit count, oracle type, upgrade pattern) can predict vulnerability class with reasonable accuracy. A machine learning model trained on pre-incident protocol states could identify at-risk protocols before attacks occur. Feature candidates include: TVL trajectory, admin key activity, oracle dependency count, audit coverage ratio, and developer activity metrics.

11.2 Cross-Ecosystem Extension

Extend the analysis to non-EVM ecosystems:

- **Solana**: SVM account model, CPI reentrancy, compute budget manipulation
- **Cosmos/IBC**: Interchain account security, IBC message verification
- **Sui/Aptos**: Move resource model, `public(friend)` access control
- **Bitcoin L2**: Emerging attack surface on sidechains and rollups

11.3 Automated 2026-Class Detection

Develop detection methods for the precision+backdoor+accounting class:

- Business-logic invariant generation from protocol specifications
- Cross-module state consistency checking via symbolic execution
- Anomaly detection on protocol accounting state over time

11.4 Defense Stratification

Develop tier-specific security recommendations:

- Tier 1 (>\$1B): Invariant formal verification + continuous monitoring
 - Tier 2 (\$100M–\$1B): TWAP oracles + reentrancy hardening + competitive audit
 - Tier 3 (\$1M–\$100M): Static analysis + manual audit + access control review
 - Tier 4 (<\$1M): Automated scanner + OpenZeppelin contract templates + basic checklist
-

12. Conclusion

This paper presents the largest longitudinal empirical study of DeFi security incidents to date, analyzing 824 attacks across the full decade 2017–2026. We identify three key findings:

1. **The attack landscape has fragmented**: High-value flash loan exploits have given way to low-value permission bugs. The median loss declined 400× while the number of protocols increased 100×. The threat has dispersed across a long tail of small, under-audited protocols.
2. **Measurable improvement exists**: The DeFi Risk Index declined 30% from 2020 to 2025, and bridge attacks — the most destructive category of 2022 — have been effectively suppressed through formal verification and validator decentralization.

3. **A new threat class has emerged:** 2026 introduces precision errors + intentional backdoors + accounting inconsistencies that resist automated detection. This represents a qualitative escalation requiring new detection paradigms.

The DeFi ecosystem faces a structural challenge: security improvement at the top tier masks persistent vulnerability in the long tail. Closing this gap — through stratified security recommendations, automated detection tools calibrated to protocol size, and economic incentives for audit adoption at smaller scales — represents the next frontier in DeFi security research.

Acknowledgments

The authors thank the DeFiHackLabs (SunWeb3Sec) community for maintaining the PoC repository that forms the foundation of this dataset. Appreciation to Rekt News, SlowMist, and CertiK for their ongoing public security reporting. Data sources: DeFiHackLabs (github.com/SunWeb3Sec/DeFiHackLabs), Rekt News (rekt.news), SlowMist Hacked (hacked.slowmist.io), CertiK Alert (alert.certik.com). TVL data sourced from DefiLlama (defillama.com).

References

- [1] Atzei, N., Bartoletti, M., & Cimoli, T. (2017). "A Survey of Attacks on Ethereum Smart Contracts (SoK)." *Proceedings of the 6th International Conference on Principles of Security and Trust (POST)*, pp. 164–186.
 - [2] Zhou, L., Xiong, X., Ernstberger, J., Chaliasos, S., Wang, Z., Wang, Y., Qin, K., Wattenhofer, R., Song, D., & Gervais, A. (2023). "SoK: Decentralized Finance (DeFi) Attacks." *IEEE Symposium on Security and Privacy (S&P)*.
 - [3] Werner, S., Perez, D., Gudgeon, L., Klages-Mundt, A., Harz, D., & Knottenbelt, W. (2023). "SoK: Decentralized Finance (DeFi)." *ACM Advances in Financial Technologies (AFT)*.
 - [4] Qin, K., Zhou, L., & Gervais, A. (2021). "Quantifying Blockchain Extractable Value: How Dark is the Forest?" *IEEE Symposium on Security and Privacy (S&P)*.
 - [5] Daian, P., Goldfeder, S., Kell, T., Li, Y., Zhao, X., Bentov, I., Breidenbach, L., & Juels, A. (2020). "Flash Boys 2.0: Frontrunning in Decentralized Exchanges, Miner Extractable Value, and Consensus Instability." *IEEE Symposium on Security and Privacy (S&P)*.
 - [6] Zhou, L., Qin, K., Torres, C. F., Le, D. V., & Gervais, A. (2021). "High-Frequency Trading on Decentralized On-Chain Exchanges." *IEEE Symposium on Security and Privacy (S&P)*.
 - [7] Chen, J., Xia, X., Lo, D., & Grundy, J. (2022). "Why Should I Trust Your Code? An Empirical Study of Smart Contract Security on Ethereum." *ACM Transactions on Software Engineering and Methodology (TOSEM)*.
-

Appendix A. Full Attack Pattern Distribution (2017–2026)

Rank	Pattern ID	Pattern	Count	Share
1	#1	Flash Loan + Oracle Manipulation	198	24.0%
2	#2	Reentrancy	165	20.0%
3	#3	Access Control / Authorization	125	15.2%
4	#4	AMM / Pool Manipulation	107	13.0%
5	#12	Business Logic Flaw	48	5.8%
6	#6	Lending / Liquidation Failure	45	5.5%
7	#7	Governance Attack	24	2.9%
8	#8	Signature / Permit Bypass	22	2.7%
9	#10	Proxy / Upgrade Vulnerability	18	2.2%
10	#13	Token Standard Non-Compliance	16	1.9%
11	#9	Cross-Chain / Bridge	14	1.7%
12	#5	ERC-4626 Inflation Attack	12	1.5%
13	#15	Private Key Compromise	10	1.2%
14	#11	Integer Overflow / Precision	8	1.0%
15	#14	MEV / Sandwich / Frontrunning	5	0.6%
16	#16	Intentional Backdoor	4	0.5%
17	#17	Accounting / State Inconsistency	3	0.4%
		Total	824	100%

Table A1. Complete distribution of the 17 attack patterns across all 824 incidents.

Dataset and replication materials available at: [10.5281/zenodo.21382653](https://doi.org/10.5281/zenodo.21382653). Paper DOI: [10.5281/zenodo.21403779](https://doi.org/10.5281/zenodo.21403779). Repository: github.com/shunfeng8421/defi-hack-memo.